tell the browser how it should behave. There are many headers available, most of which restrict the features your app can use in exchange for increased security. In chapter 30 you'll see how to add your own custom headers to your HTTP responses by creating custom middleware.

TIP Scott Helme has some great guidance on this and other security headers you can add to your site, such as the Content Security Policy (CSP) header. See "Hardening your HTTP response headers" on his website at http://mng.bz/7DDe.

One of these security headers, the HTTP Strict Transport Security (HSTS) header, can help ensure that browsers use HTTPS where it's available instead of defaulting to HTTP.

28.4.1 Enforcing HTTPS with HTTP Strict Transport Security headers

It's unfortunate, but by default, browsers load apps over HTTP unless otherwise specified. That means your apps must typically support both HTTP and HTTPS, even if you don't want to serve any traffic over HTTP, as shown in figure 28.6. On top of that, if the initial request is over HTTP, the browser may end up sending subsequent requests over HTTP too.